

Отчёт по лабораторной работе №2

Кибербезопасность предприятия

Абакумова Олеся,
Герра Гарсия Максимиано Антонио,
Канева Екатерина,
Клюкин Михаил,
Ланцова Яна,
НФИбд-02-22

Содержание

1	Цель работы	6
2	Выполнение лабораторной работы	7
2.1	Уязвимость 1. CVE-2020-24186.	7
2.2	Последствие уязвимости 1	14
2.3	Уязвимость 2. CVE 2021-27065.	15
2.4	Последствие уязвимости 2	17
2.4.1	Meterpreter-сессия	18
2.4.2	Web-shell China Chopper	19
2.5	Уязвимость 3. CVE-2021-22911.	20
2.6	Борьба за вход в Rocket Chat	23
2.7	Устранение последствия уязвимости 3	29
3	Выводы	32

Список иллюстраций

2.1	Найдено нарушение правил	7
2.2	Найдена атака на веб-приложение	8
2.3	Просмотр обзора события	8
2.4	Схема атаки	9
2.5	Просмотр подозрительного запроса через SecOnion	9
2.6	Добавление инцидента по уязвимости 1	9
2.7	Подключение к устройству	10
2.8	Вход веб-сайт 10.10.1.22	10
2.9	Страница плагинов на веб-сайте	11
2.10	Отключение плагина WpDiscuz	11
2.11	Страница сайта компании	12
2.12	Список резервных копий	12
2.13	Выбор компонентов переустановки	13
2.14	Сообщение об удалении директорий	13
2.15	Успешное восстановление предыдущей версии	14
2.16	Отображение информации о TCP-соединениях и закрытие сессии	14
2.17	Уязвимость и последствия первой уязвимости устранены	15
2.18	Обнаружение подозрительного события	15
2.19	Карточка второго инцидента	16
2.20	Окно Internet Information Services (IIS) Manager	17
2.21	«IP Address and Domain Restrictions»	17
2.22	Завершение процесса	19
2.23	Удаление файла web-оболочки	20
2.24	События ИБ в сетевом сенсоре ViPNet IDS NS	21
2.25	Карточка инцидента третьей уязвимости	21
2.26	Сброс пароля	22
2.27	Ссылка для сброса пароля	22
2.28	Создание нового пароля	23
2.29	Проверка наличия БД	24
2.30	Остановка службы и удаление БД	25
2.31	Восстановление БД из бэкапа	25
2.32	Запуск RocketChat	26
2.33	Редактирование конфигурации БД	27
2.34	Коды восстановления	27
2.35	Ввод кода	28
2.36	Успешный вход	29
2.37	Находим сессию с нарушителем с пометкой testsystem	30

2.38	Закрытие сессии с нарушителем	30
2.39	Закрытые инциденты	31
2.40	Закрытые инциденты	31

Список таблиц

1 Цель работы

Устранить уязвимости и последствия для корпоративного мессенджера.

2 Выполнение лабораторной работы

2.1 Уязвимость 1. CVE-2020-24186.

Начнём выполнение лабораторной, зайдём в список событий и найдём информацию о произошедшей атаке (рис. 2.1). В списках событий видно, что система безопасности обнаружила в сетевом трафике вредоносный программный код (EXPLOIT), предназначенный для эксплуатации уязвимости в системе (рис. 2.2).

События

События за последние 24 часа

У...	Дата и время	Код событ...	К...	Название правила	Класс	Протокол	IP-адрес исто...	Порт ис...	IP-адрес полу...	Порт по...	Направл...
	14:17:30.160 10...	3006261	1	AM POLICY RDP session en...	network-scan	TCP	10.10.2.254	43920	10.10.2.10	3389	→
	14:17:30.160 10...	3006261	1	AM POLICY RDP session en...	network-scan	TCP	10.10.4.12	61156	10.10.2.10	3389	→
	14:17:30.056 10...	2001330	1	ET INFO RDP - Response To...	misc-activity	TCP	10.10.2.10	3389	10.10.4.12	61156	→
	14:17:30.056 10...	2001330	1	ET INFO RDP - Response To...	misc-activity	TCP	10.10.2.10	3389	10.10.2.254	43920	→
	11:42:12.633 10...	3039900	1	AM CURRENT_EVENTS Tra...	bad-unknown	TCP	10.10.2.10	445	10.10.2.11	8852	→
	11:32:07.257 10...	3121915	1	ET POLICY Executable and L...	policy-violation	TCP	195.239.174.11	5559	10.10.2.22	41686	→
	11:32:07.256 10...	3121915	1	ET POLICY Executable and L...	policy-violation	TCP	195.239.174.11	5559	10.10.1.253	56041	→
	11:32:02.145 10...	3129327	1	ET POLICY Executable and L...	policy-violation	TCP	195.239.174.11	8010	10.10.2.22	36932	→
	11:32:02.145 10...	3129327	1	ET POLICY Executable and L...	policy-violation	TCP	195.239.174.11	8010	10.10.1.253	64039	→
	11:30:07.018 10...	2025644	1	ET TROJAN Possible Metas...	trojan-activity	TCP	195.239.174.11	5558	10.10.2.11	7330	→
	11:30:07.018 10...	2025644	1	ET TROJAN Possible Metas...	trojan-activity	TCP	195.239.174.11	5558	10.10.1.253	15137	→
	11:30:07.014 10...	2035480	1	ET INFO PE EXE Download ...	misc-activity	TCP	195.239.174.11	5558	10.10.2.11	7330	→
	11:30:07.014 10...	2035480	1	ET INFO PE EXE Download ...	misc-activity	TCP	195.239.174.11	5558	10.10.1.253	15137	→
	11:30:06.891 10...	2025644	1	ET TROJAN Possible Metas...	trojan-activity	TCP	195.239.174.11	5558	10.10.2.11	7329	→

Рис. 2.1: Найдено нарушение правил

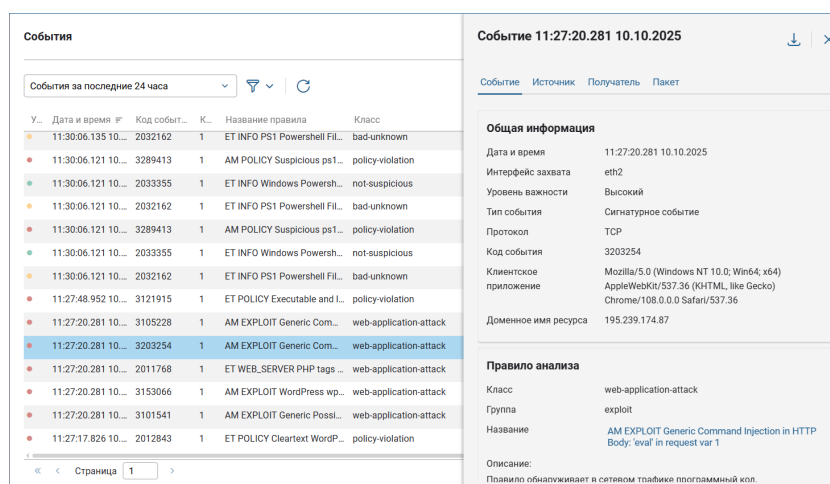


Рис. 2.2: Найдена атака на веб-приложение

Найденное событие фиксирует успешную попытку внедрения операционной команды на веб-сервер. Атакующий сумел передать на сервер в теле HTTP-запроса данные, которые содержали команду для выполнения на самой ОС сервера.

Посмотрим как нейтрализовать найденную уязвимость по CVE, чтобы получить точную информацию о характере уязвимости и ее критичности (рис. 2.3).

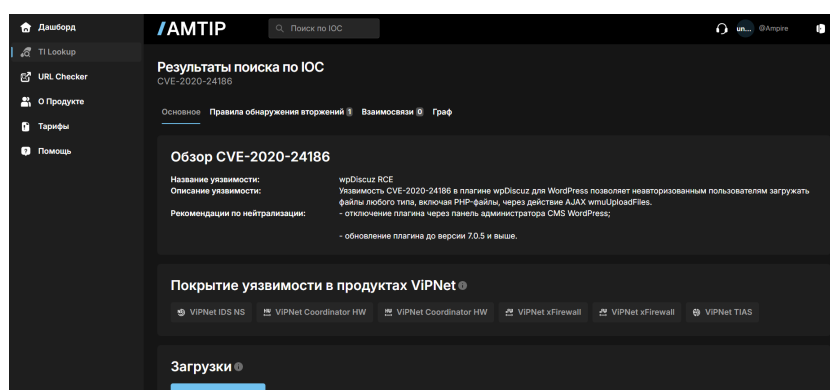


Рис. 2.3: Просмотр обзора события

Посмотрим графическую схему корпоративной сети. Атакующий с рабочей станции Kali Linux проводит атаку на один из DMZ серверов компании (рис. 2.4).

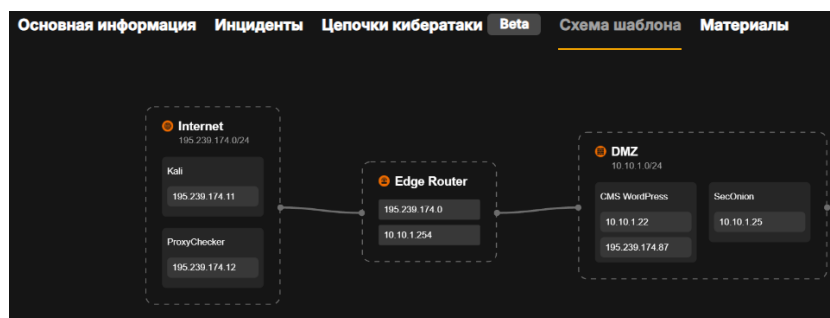


Рис. 2.4: Схема атаки

Проанализируем пакет с подозрительным HTTP-запросом через SecOnion, отфильтровав по уязвимому узлу (рис. 2.5).

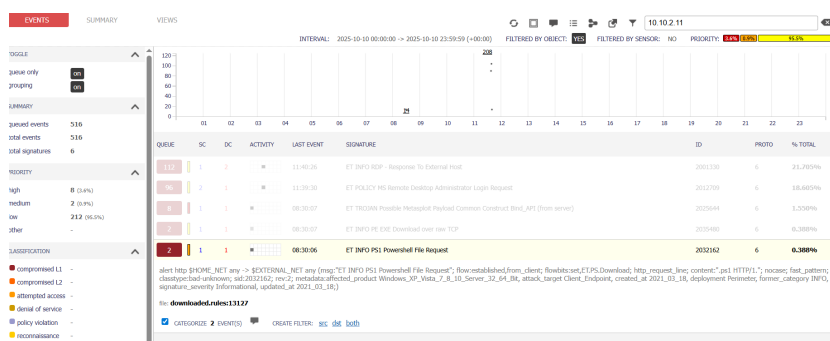


Рис. 2.5: Просмотр подозрительного запроса через SecOnion

Изучили уязвимость, добавили инцидент (рис. 2.6).

Дата и время события

10.10.2025 11:30

Описание

Правило обнаруживает в сетевом трафике программный код, предназначенный для эксплуатации уязвимости

Индикаторы компрометации

Найдено подозрительное событие

Рекомендации

- отключение плагина через панель администратора CMS WordPress; - обновление плагина до версии 7.0.5 и выше.

Прикрепленные файлы

IDS_packet_time-2025-10-10T08_27.20.2815237_ruleid-3101541.pcap

Оценка

☆☆☆☆

Автор

Абакумова Олеся @1132220832@pfur.ru

Ответственный

Герра Гарсия Максимиано Антонио @1132220832@pfur.ru

Источник

195.239.174.11

Пораженные активы

10.10.1.22

Рис. 2.6: Добавление инцидента по уязвимости 1

Для устранения уязвимости подключимся к атакованному устройству через

удаленный рабочий администратора стол с помощью KeyPass (рис. 2.7).

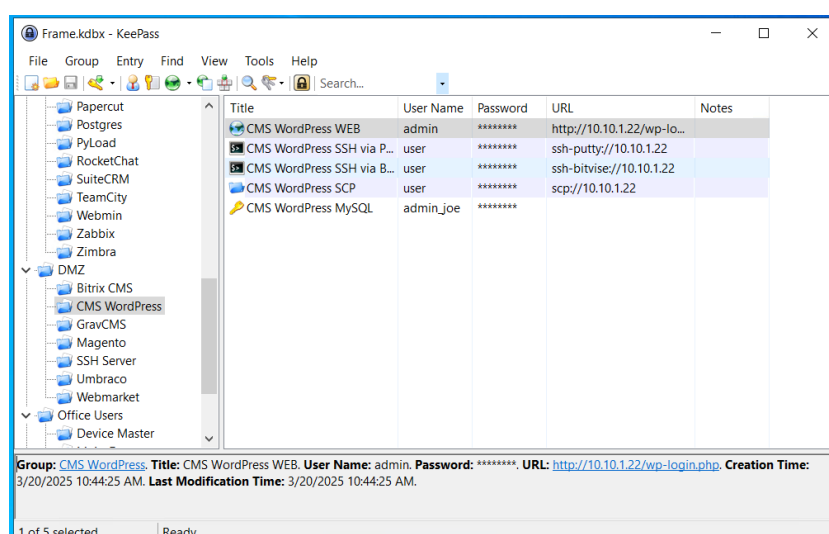


Рис. 2.7: Подключение к устройству

Залогинемся на веб-сайте под администратором (рис. 2.8).

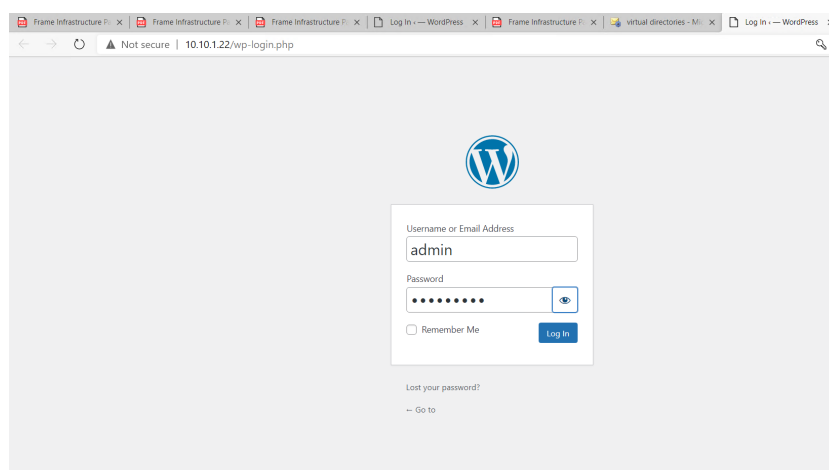


Рис. 2.8: Вход веб-сайт 10.10.1.22

Перейдем в раздел плагинов на сайте и найдем требующийся (рис. 2.9).

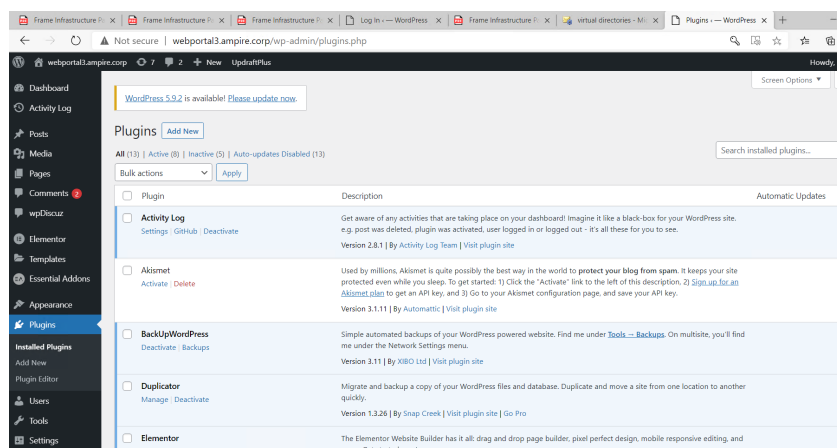


Рис. 2.9: Страница плагинов на веб-сайте

Для устранения уязвимости, необходимо было или деактивировать плагин WpDiscuz, который был точкой входа для атакующего. Данная уязвимость исправлена разработчиками в версии 7.0.5 и выше. Для закрытия уязвимости достаточно обновить версию плагина WpDiscuz на более актуальную, однако у нас отсутствует подключение к интернету. Поэтому отключим данный плагин по выбранной причине (рис. 2.10).

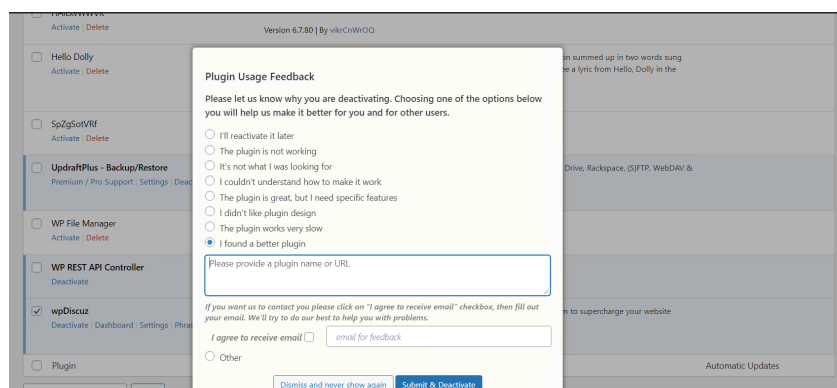


Рис. 2.10: Отключение плагина WpDiscuz

Открыв страницу сайта компании <http://webportal3.ampire.corp> увидим изменения (рис. 2.11):

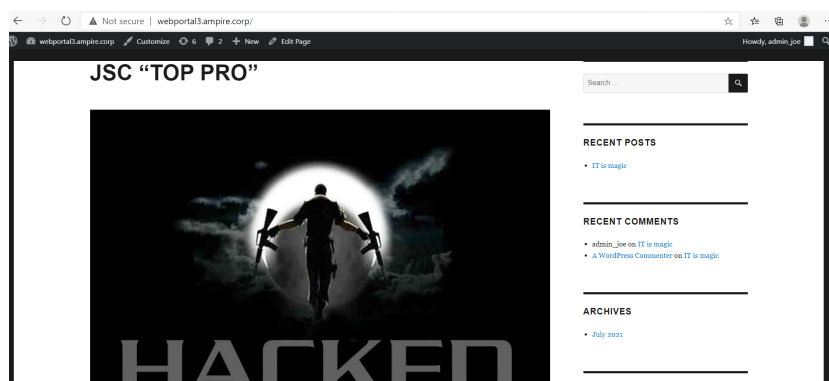


Рис. 2.11: Страница сайта компании

Чтобы устранить уязвимость необходимо выполнить восстановление из последнего файла резервной копии, поскольку на веб-сервере работает FTP-сервер vsftpd, который дает возможность плагину Updraft Backup/Restore сохранять и скачивать резервную копию.

Посмотрим последние резервные копии на сайте (рис. 2.12).

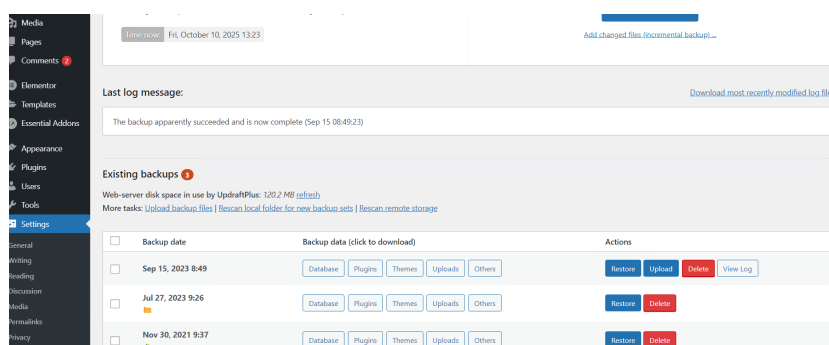


Рис. 2.12: Список резервных копий

Активируем версию от 15 сентября 2023 года и попытаемся восстановить данные. В качестве компонентов для переустановки укажем Themes и Uploads (рис. 2.13).

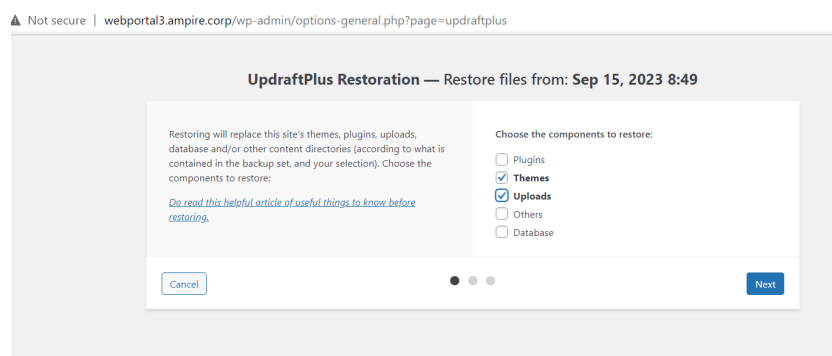


Рис. 2.13: Выбор компонентов переустановки

Поскольку возникла ошибка восстановления, нужно нажать опцию Delete Old Directories в журнале действий (рис. 2.14):

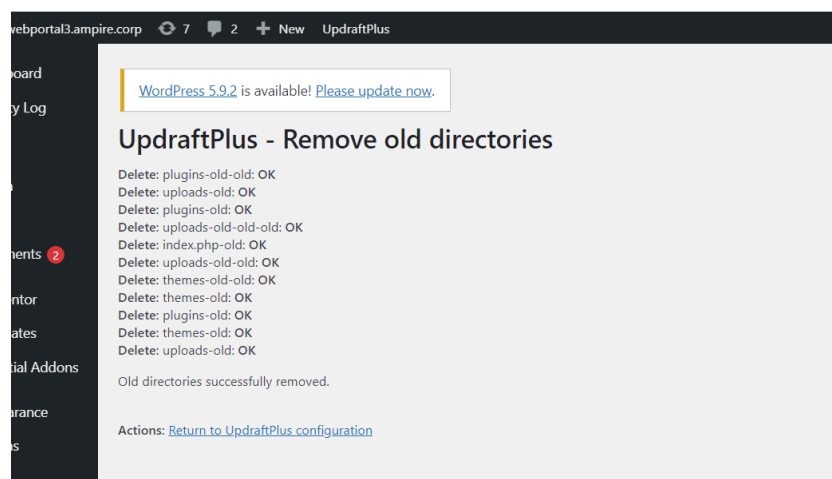


Рис. 2.14: Сообщение об удалении директорий

Перейдем к возврату конфигурации, активировав опцию Return to configuration (рис. 2.15):

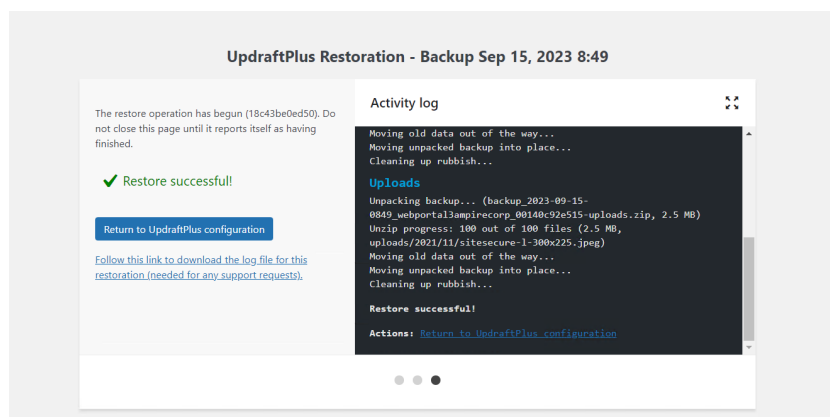


Рис. 2.15: Успешное восстановление предыдущей версии

2.2 Последствие уязвимости 1

Чтобы устранить последствие, подключимся к консоли атакуемого устройства. Проверим сокет уязвимой машины на подключение к определенному порту машины и обнаружим соединение с Kali. Разорвем соединение с нарушителем и проверим, что лишних соединений нет (рис. 2.16):

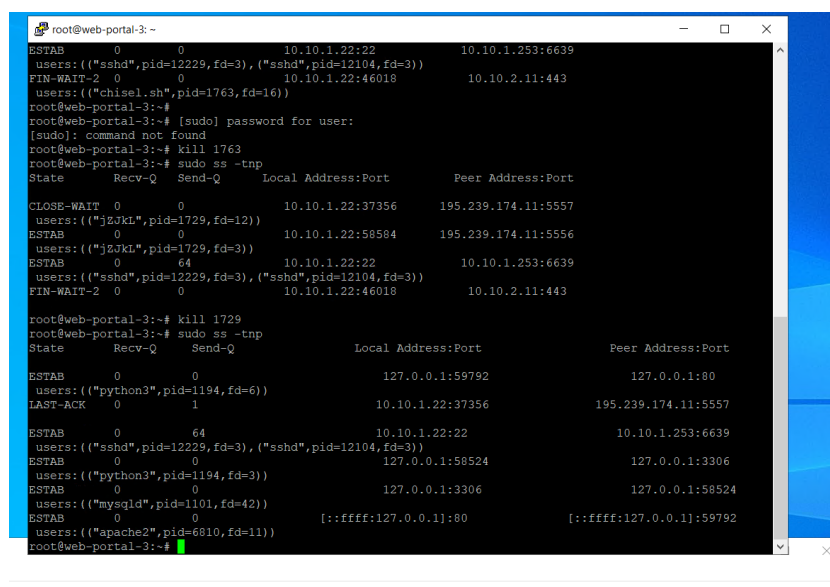


Рис. 2.16: Отображение информации о TCP-соединениях и закрытие сессии

Таким образом, устранили уязвимость, последствия первой уязвимости и за-

крыли инцидент (рис. 2.17):

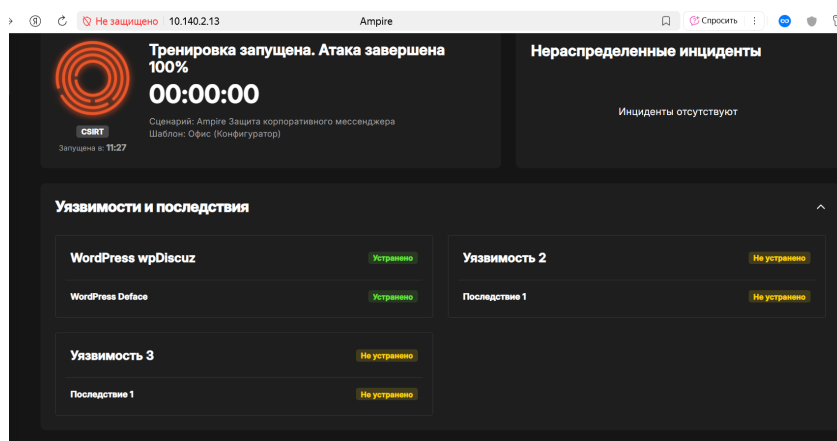


Рис. 2.17: Уязвимость и последствия первой уязвимости устранены

2.3 Уязвимость 2. CVE 2021-27065.

Вернемся в список событий и обнаружим следующее сигнатурное событие в системе – возможное нарушение политики информационной безопасности (рис. 2.18):

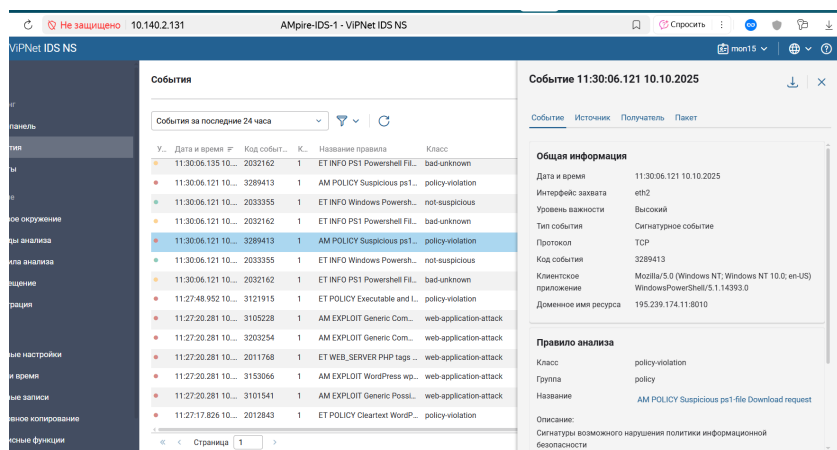


Рис. 2.18: Обнаружение подозрительного события

После обнаружения данного события в системе время создать карточку нового инцидента (рис. 2.19):

Рис. 2.19: Карточка второго инцидента

Указав всю необходимую информацию об инциденте можем перейти к **устранению уязвимости**.

Во время эксплуатации уязвимости Proxylogon нарушитель совершает GET и POST запросы к /еср. Достаточно ограничить доступ к указанной директории для запрета эксплуатации уязвимости.

Необходимо выполнить следующие действия:

1. Для открытия Internet Information Services (IIS) Manager необходимо нажать сочетание клавиш Win + R и в появившемся окне ввести inetmgr и нажать Enter.
2. В открывшемся окне перейти во вкладку MAIL\Sites\Default Web Site\еср и нажать на IP Address and Domain Restrictions (рис. 2.20):

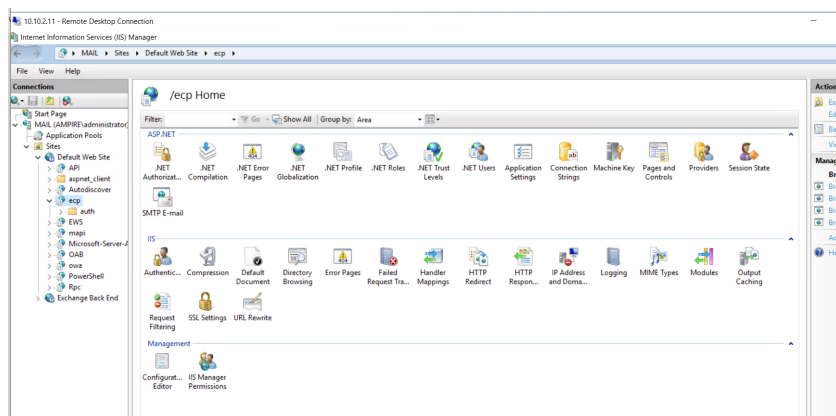


Рис. 2.20: Окно Internet Information Services (IIS) Manager

3. Далее в «Edit Feature Settings» – «Access for unspecified clients» выбрать пункт «Deny» и нажать «OK» (рис. 2.21):

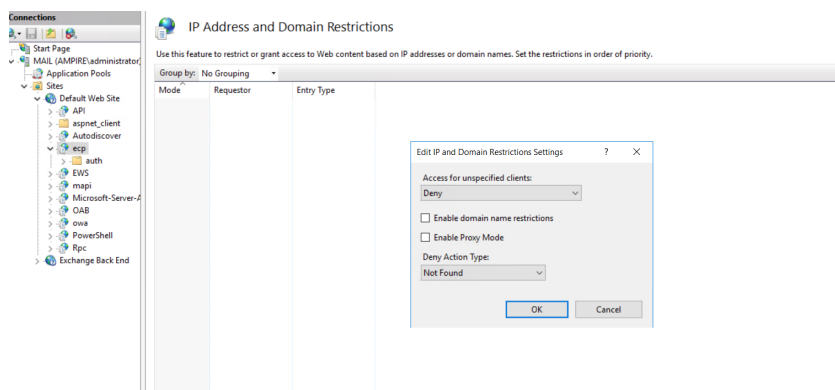


Рис. 2.21: «IP Address and Domain Restrictions»

Следует отметить, что индикатор устранения уязвимости не изменится, пока не будет устранено последствие в виде вредоносного meterpreter-соединения.

2.4 Последствие уязвимости 2

Уязвимый узел позволяет реализовать следующие виды полезной нагрузки:

1. meterpreter-сессия;
2. web-shell China Chopper;

3. registry backdoor;
4. file encryption;
5. service backdoor;
6. IIS backdoor;
7. добавление пользователя системы Windows;
8. Task Scheduler backdoor;
9. SmartScreen Spoof.

В контексте устранения последствий рассмотрим **meterpreter- сессию**.

2.4.1 Meterpreter-сессия

Данная полезная нагрузка заключается в получении нарушителем meterpreter-сессии с уязвимым сервером.

Данную полезную нагрузку можно обнаружить с помощью утилиты netstat с ключами -b -с. В случае установления соединения на уязвимой машине появится сокет с машиной нарушителя. Для закрытия meterpreter-сессии необходимо завершить процесс данного соединения с помощью команды taskkill /PID <PID> /F. Данная команда в системе Windows используется для принудительного завершения процесса. На вход команда taskkill получает идентификатор процесса PID и параметр команды /F, который указывает на принудительное завершение процесса. (рис. 2.22):

```
Administrator: Command Prompt
[w3wp.exe]
TCP 10.10.2.11:14791 ad:ldap ESTABLISHED 10856
[w3wp.exe]
TCP 10.10.2.11:16048 ad:ldap ESTABLISHED 3736
[Microsoft.Exchange.Search.Service.exe]
TCP 10.10.2.11:16049 ad:ldap ESTABLISHED 3736
[Microsoft.Exchange.Search.Service.exe]
TCP 10.10.2.11:16482 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16484 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16485 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16486 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16487 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16488 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16489 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16490 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16491 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16493 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16494 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16495 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16496 195.239.174.12:https TIME_WAIT 0
TCP 10.10.2.11:16497 195.239.174.12:https TIME_WAIT 0
^C
C:\Users\administrator.AMPIRE>taskkill /PID 12904 /F
SUCCESS: The process with PID 12904 has been terminated.
```

Рис. 2.22: Завершение процесса

Соединение с нарушителем ликвидировано.

2.4.2 Web-shell China Chopper

Также следует обратить внимание на Web-shell China Chopper. Backdoor «China Chopper» можно найти в очевидной для таких атак директории C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\AM_backdoor.aspx.

Большинство РОС (проверок концепций) эксплуатации уязвимости Proxylogon записывают файл именно по данному адресу, что выполняется для доступа backdoor без авторизации из веб-директории owa/auth. При необходимости полезную нагрузку можно записать в другую директорию.

Для устранения полезной нагрузки необходимо:

- удалить файл веб-оболочки по пути C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\..\auth\ (рис. 2.23):

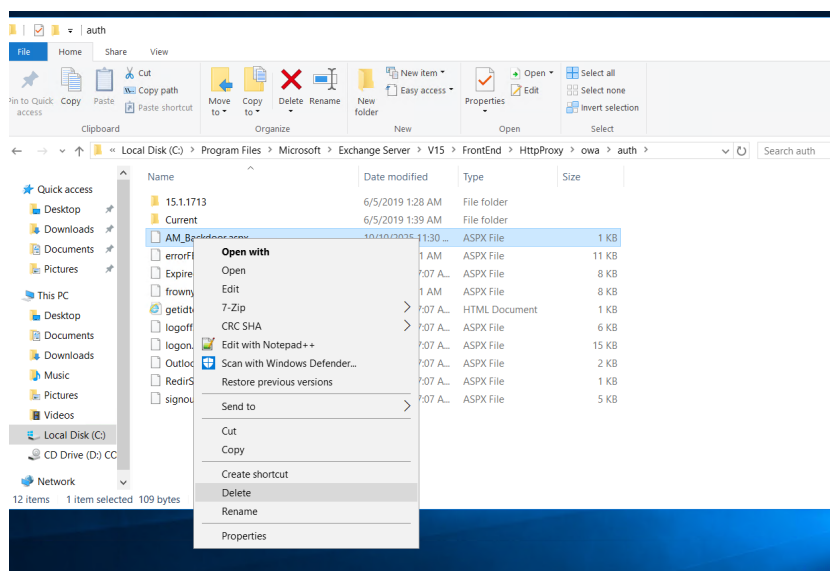


Рис. 2.23: Удаление файла web-оболочки

- завершить все соединения между уязвимой машиной и нарушителем (рис. 2.22).

После проделанных действий, уязвимость 2 и ее последствие будут устранены.

2.5 Уязвимость 3. CVE-2021-22911.

Непосредственно эксплуатацию уязвимости обнаружить при помощи сетевого сенсора ViPNet IDS NS не получится, однако успешно детектируются последствия, а именно скачивание вредоносного файла для установки обратного TCP-соединения (meterpreter-сессии) и на каком порту установлено соединени е (рис. 2.24):

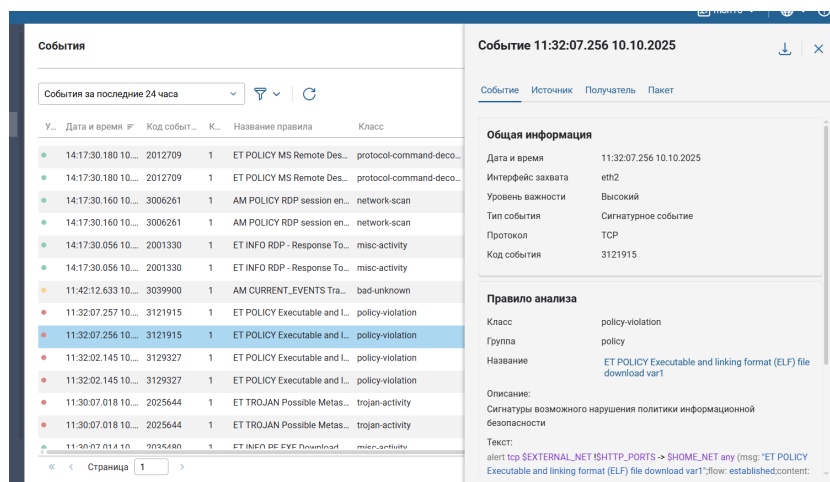


Рис. 2.24: События ИБ в сетевом сенсоре VipNet IDS NS

Создадим последнюю карточку инцидента (рис. 2.25):

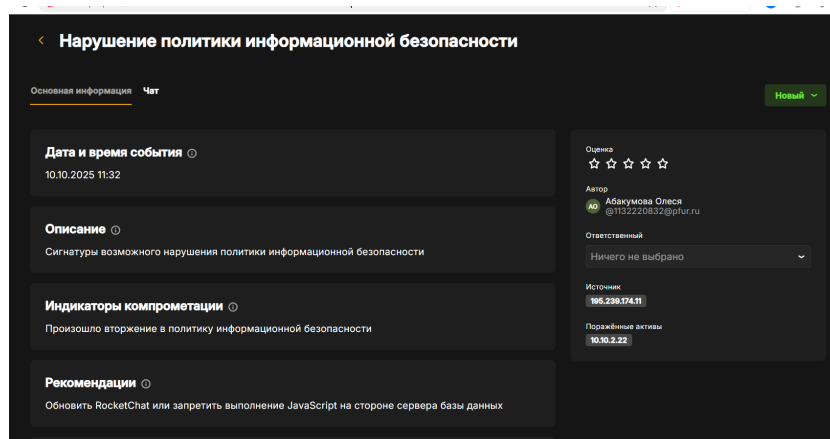


Рис. 2.25: Карточка инцидента третьей уязвимости

Заполнив все поля, можно перейти к устранению.

Для восстановления доступа к аккаунту администратора необходимо сбросить пароль (рис. 2.26):

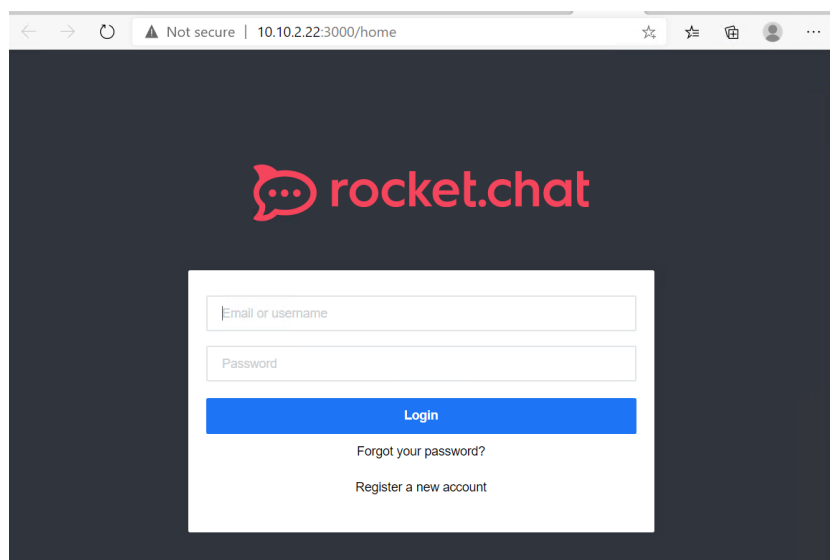


Рис. 2.26: Сброс пароля

Письмо с инструкциями для сброса пароля можно прочитать при помощи утилиты mail (переключившись на учетную запись admin), либо при помощи текстового редактора, прочитав файл /var/mail/admin (рис. 2.27):

```
admin@rocket-chat-server: /var/mail
boundary="-- NmP-c5c0b6c252198e5a-Part_1"
From: "Rocket.Chat" <rocketchat@rocket-local.com>
To: admin@rocket-local.com
Subject: Rocket.Chat - Password Recovery
Message-ID: <e2dc06e0-84a1-5ce4-d3b3-f45689f15b4b@rocket-local.com>
Date: Fri, 10 Oct 2025 14:25:18 +0000
MIME-Version: 1.0

---- NmP-c5c0b6c252198e5a-Part_1
Content-Type: text/plain
Content-Transfer-Encoding: quoted-printable

Hello,

To reset your password, simply click the link below.

http://10.10.2.22:3000/reset-password/0zTtpHnmGWvg-dROS9IV4VQGD-W3zhknRWgv=MM28Tc

Thanks.

---- NmP-c5c0b6c252198e5a-Part_1
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable
```

Рис. 2.27: Ссылка для сброса пароля

Нужно обратить внимание, что в терминале при переносе строки используется знак «=», его следует игнорировать.

После этого необходимо ввести новый пароль. Для учетной записи администра-

тора Rocket Chat настроена двухфакторная аутентификация при помощи TOTP (Time-based one-time password). Для генерации одноразового пароля необходимо воспользоваться программой Keeypass, доступной на машине администрирования (рис. 2.28):

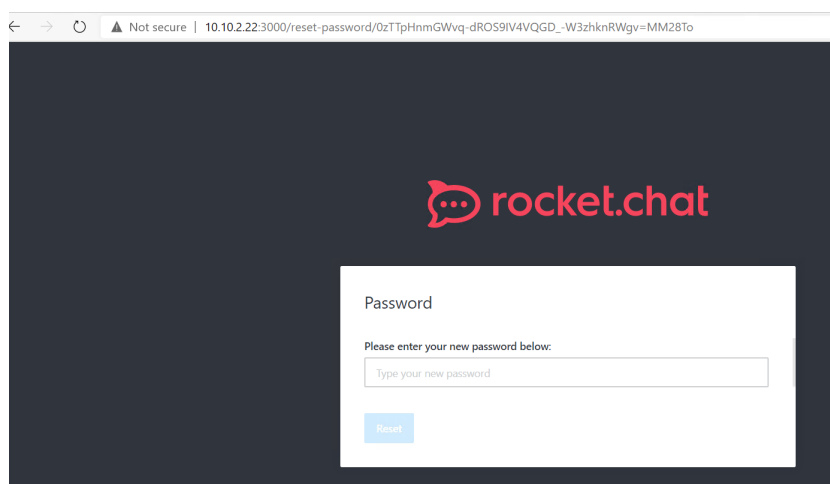


Рис. 2.28: Создание нового пароля

Конечно же у меня ничего не получилось с первого раза, но мы не сдаемся.

2.6 Борьба за вход в Rocket Chat

Если восстановить доступ к учетной записи администратора не получается (не приходит письмо, не находит пользователя), необходимо сначала восстановить БД rocketchat.

Проверить наличие БД можно при помощи консоли управления СУБД, подключившись к которой можно командой `mongo`, выполнив команды (рис. 2.29):

```

rs01:PRIMARY> show dbs
admin          0.000GB
config         0.000GB
local          0.002GB
rocketchat     0.006GB
rs01:PRIMARY> use rocketchat
switched to db rocketchat
rs01:PRIMARY> show collections
_raix_push_app_tokens
instances
meteor_accounts_loginServiceConfiguration
meteor_oauth_pendingCredentials
meteor_oauth_pendingRequestTokens
migrations
omnichannel_scheduler
rocketchat__trash
rocketchat_analytics
rocketchat_apps
rocketchat_apps_logs
rocketchat_apps_persistence
rocketchat_apps_scheduler
rocketchat_avatars
rocketchat_avatars.chunks

```

Рис. 2.29: Проверка наличия БД

Как видно из рисунка, БД rocketchat существует (так как были попытки аутентификации в Rocket Chat), однако в ней нет необходимых коллекций для корректного функционирования сервиса (должно быть 72 коллекции). Для восстановления БД можно воспользоваться бэкапом, созданным ранее, или заново проинициализировать БД. Для того чтобы в БД не записывалась никакая «мусорная» информация, необходимо остановить службу Rocket Chat. Также удалим базу и проверим корректность удаления (рис. 2.30):


```

admin@rocket-chat-server:/var/mail$ sudo systemctl stop rocketchat
admin@rocket-chat-server:/var/mail$ mongo rocketchat --eval "db.dropDatabase()"
MongoDB shell version v4.2.19
connecting to: mongodb://127.0.0.1:27017/rocketchat?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("fea2569f-e39b-48b1-8c23-67ba14cc2810") }
MongoDB server version: 4.2.19
{
  "dropped" : "rocketchat",
  "ok" : 1,
  "$clusterTime" : {
    "clusterTime" : Timestamp(1760124944, 73),
    "signature" : {
      "hash" : BinData(0,"AAAAAAAAAAAAAAAAAAAAAAAAAAAA="),
      "keyId" : NumberLong(0)
    }
  },
  "operationTime" : Timestamp(1760124944, 73)
}
admin@rocket-chat-server:/var/mail$ mongo --eval "db.adminCommand('listDatabases')"
MongoDB shell version v4.2.19
connecting to: mongodb://127.0.0.1:27017?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("bb45512b-5f92-4fa8-909c-810bbd285507") }
MongoDB server version: 4.2.19
{
  "databases" : [
    {
      "name" : "admin",
      "sizeOnDisk" : 114688,
      "empty" : false
    },
    {
      "name" : "config",
      "sizeOnDisk" : 126976,
      "empty" : false
    },
    {
      "name" : "local",
      "sizeOnDisk" : 2084864,
      "empty" : false
    }
  ],
  "totalSize" : 2326528,
  "ok" : 1,
  "$clusterTime" : {
    "clusterTime" : Timestamp(1760124944, 73),
    "signature" : {
      "hash" : BinData(0,"AAAAAAAAAAAAAAAAAAAAAAAAAAAA="),
      "keyId" : NumberLong(0)
    }
  },
  "operationTime" : Timestamp(1760124944, 73)
}
admin@rocket-chat-server:/var/mail$

```

Рис. 2.30: Остановка службы и удаление БД

Теперь восстановим БД из бэкапа (рис. 2.31):

```

admin@rocket-chat-server:/var/mail$ mongo --eval "db.adminCommand('listDatabases')"
MongoDB shell version v4.2.19
connecting to: mongodb://127.0.0.1:27017?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("bb45512b-5f92-4fa8-909c-810bbd285507") }
MongoDB server version: 4.2.19
{
  "databases" : [
    {
      "name" : "admin",
      "sizeOnDisk" : 114688,
      "empty" : false
    },
    {
      "name" : "config",
      "sizeOnDisk" : 126976,
      "empty" : false
    },
    {
      "name" : "local",
      "sizeOnDisk" : 2084864,
      "empty" : false
    }
  ],
  "totalSize" : 2326528,
  "ok" : 1,
  "$clusterTime" : {
    "clusterTime" : Timestamp(1760124944, 73),
    "signature" : {
      "hash" : BinData(0,"AAAAAAAAAAAAAAAAAAAAAAAAAAAA="),
      "keyId" : NumberLong(0)
    }
  },
  "operationTime" : Timestamp(1760124944, 73)
}
admin@rocket-chat-server:/var/mail$ sudo mongorestore --db rocketchat --drop /var/backups/mongobackups/rocketchat
2025-10-10T19:38:49.371+0000 the --db and --collection args should only be used when restoring from a BSON file. Oth
2025-10-10T19:38:49.374+0000 building a list of collections to restore from /var/backups/mongobackups/rocketchat/dis
2025-10-10T19:38:49.390+0000 reading metadata for rocketchat.rocketchat_settings from /var/backups/mongobackups/rock

```

Рис. 2.31: Восстановление БД из бэкапа

Теперь запустим RocketChat и проверим статус (рис. 2.32):

```
2025-10-10 19:38:54.194+0000    2081 document(s) restored successfully, 0 document(s) failed to restore
admin@rocket-chat-server:/var/mail$ sudo systemctl start rocketchat
admin@rocket-chat-server:/var/mail$ sudo systemctl status rocketchat
● rocketchat.service - The Rocket.Chat server
   Loaded: loaded (/lib/systemd/system/rocketchat.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2025-10-10 19:39:02 UTC; 7s ago
     Main PID: 3227 (node)
       Tasks: 11 (limit: 4608)
      Memory: 405.0M
    CGroup: /system.slice/rocketchat.service
            └─3227 /usr/bin/node /opt/Rocket.Chat/main.js

Oct 10 19:39:02 rocket-chat-server systemd[1]: Started The Rocket.Chat server.
Oct 10 19:39:03 rocket-chat-server rocketchat[3227]: (node:3227) [DEP0131] DeprecationWarning: The legacy
admin@rocket-chat-server:/var/mail$ mongo --eval "db.adminCommand('listDatabases')"
MongoDB shell version v4.2.19
connecting to: mongodb://127.0.0.1:27017/?compressors=disabled&gssapiServiceName=mongod
Implicit session: session { "id" : UUID("2e4f78aa-36a0-44b1-84c7-60909798c571") }
MongoDB server version: 4.2.19
{
  "databases" : [
    {
      "name" : "admin",
      "sizeOnDisk" : 114688,
      "empty" : false
    },
    {
      "name" : "config",
      "sizeOnDisk" : 126976,
      "empty" : false
    },
    {
      "name" : "local",
      "sizeOnDisk" : 2076672,
      "empty" : false
    },
    {
      "name" : "rocketchat",
      "sizeOnDisk" : 3813376,
      "empty" : false
    }
  ],
  "totalSize" : 6131712,
  "ok" : 1,
  "$clusterTime" : {
    "clusterTime" : Timestamp(1760125157, 1),
    "signature" : {
      "hash" : BinData(0,"AAAAAAAAAAAAAAAAAAAAAAAA"),
      "keyId" : NumberLong(0)
    }
  },
  "operationTime" : Timestamp(1760125157, 1)
}
admin@rocket-chat-server:/var/mail$ mongo rocketchat --eval "db.getCollectionNames()"
Активация W
Чтобы активировать
```

Рис. 2.32: Запуск RocketChat

На рисунке выше также видно, что БД корректно восстановлена.

Внесем изменения в настройки конфигурации БД. Для этого необходимо отредактировать файл конфигурации БД /etc/mongod.conf, добавив строку javascriptEnabled: false (рис. 2.33):

```
root@rocket-chat-server: /etc
GNU nano 4.8                                mongod.conf
# where to write logging data.
systemLog:
  destination: file
  logAppend: true
  path: /var/log/mongodb/mongod.log

# network interfaces
net:
  port: 27017
  bindIp: 127.0.0.1

# how the process runs
processManagement:
  timeZoneInfo: /usr/share/zoneinfo

security:
  javascriptEnabled: false

operationProfiling:

^G Get Help  ^O Write Out ^W Where Is  ^K Cut Text  ^J Just
^X Exit      ^R Read File ^\ Replace   ^U Paste Text ^T To S
```

Рис. 2.33: Редактирование конфигурации БД

Когда параметр `javascriptEnabled` отключен, нельзя использовать операции, выполняющие код JavaScript на стороне сервера, такие как `$where`, оператор запроса `mapReduce`, команды `$accumulator` и `$function`. Для применения настроек необходимо перезапустить службу: `sudo systemctl restart mongod.service`.

Теперь вернемся к входу в Rocket Chat. Также выполняем процедуру сброса пароля (рис. 2.26) и запрашиваем ссылку на почту (рис. 2.27). Воспользуемся кодами для восстановления, которые записаны в файле `/home/user/backup_codes` (рис. 2.34):

```
root@rocket-chat-server:~# cd /home/user
root@rocket-chat-server:/home/user# cat backup_codes
backup codes for admin Rocket Chat:
iFdDR68y kpMifh9E 43FxEyom jho4DGdw RiuvYGrg LohP2b4A 9tiK2Sca THHC87gf mnFEZACy rdhcBy8B DvPHRnTz 5ZPgeko2
root@rocket-chat-server:/home/user#
```

Рис. 2.34: Коды восстановления

Воспользуемся одним из них (рис. 2.35):

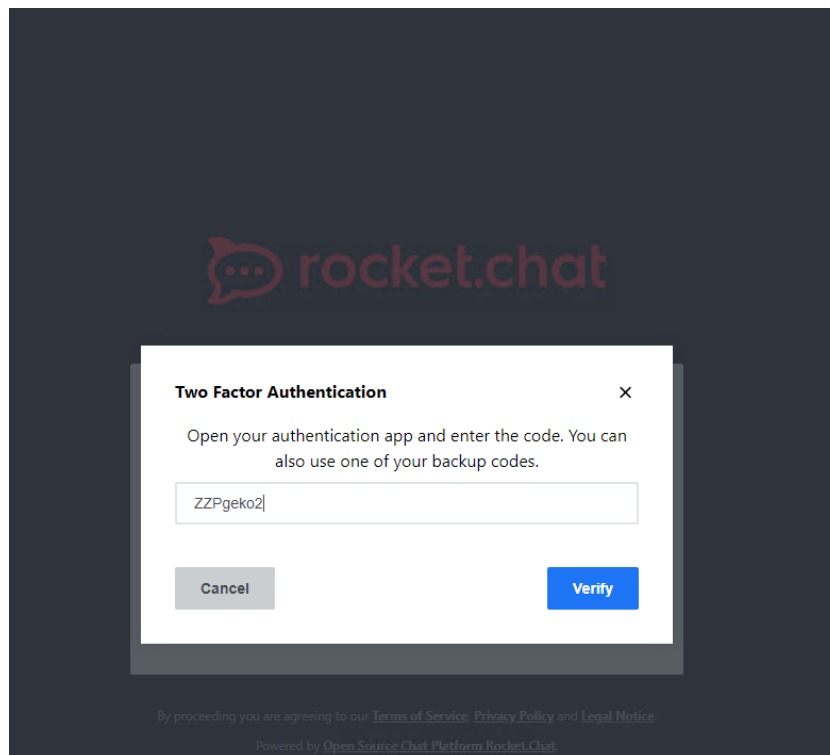


Рис. 2.35: Ввод кода

И происходит невероятное, мы заходим в Rocket Chat (рис. 2.36):

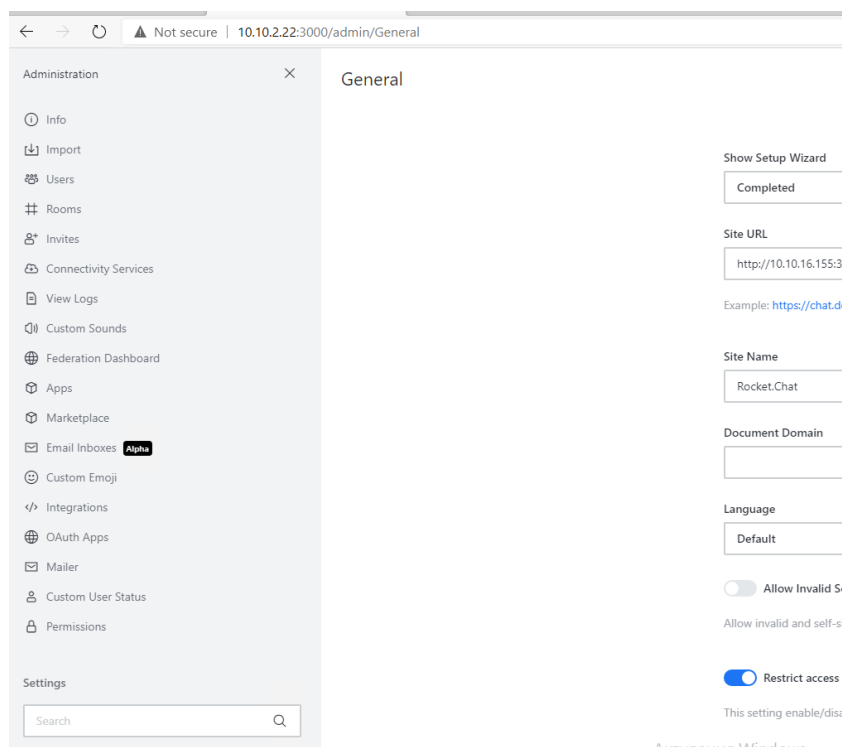


Рис. 2.36: Успешный вход

2.7 Устранение последствия уязвимости 3

Чтобы окончательно закрыть уязвимость и последствие мы закроем сессию с парашуителем (рис. 2.37):

```
root@rocket-chat-server: /etc
ESTAB      0      0      127.0.0.1:59090      127.0.0.1:27017
users: (("python3",pid=673,fd=4))
ESTAB      0      0      10.10.2.22:3000      10.10.2.254:16379
users: (("node",pid=679,fd=41))
ESTAB      0      0      127.0.0.1:59030      127.0.0.1:27017
users: (("node",pid=679,fd=22))
ESTAB      0      0      127.0.0.1:59046      127.0.0.1:27017
users: (("node",pid=679,fd=30))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59056
users: (("mongod",pid=13568,fd=103))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59022
users: (("mongod",pid=13568,fd=71))
ESTAB      0      0      10.10.2.22:41686      195.239.174.11:5559
users: (("testsystem",pid=1925,fd=3))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59046
users: (("mongod",pid=13568,fd=95))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59030
users: (("mongod",pid=13568,fd=79))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59044
users: (("mongod",pid=13568,fd=93))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59040
users: (("mongod",pid=13568,fd=89))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59072
users: (("mongod",pid=13568,fd=116))
```

Рис. 2.37: Находим сессию с нарушителем с пометкой testsystem

Закрываем сессию (рис. 2.38):

```
root@rocket-chat-server: /etc
ESTAB      0      0      127.0.0.1:59052      127.0.0.1:27017
users: (("node",pid=679,fd=33))
ESTAB      0      64      10.10.2.22:ssh      10.10.2.254:33411
users: (("sshd",pid=14978,fd=4), ("sshd",pid=14902,fd=4))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59462
users: (("mongod",pid=13568,fd=152))
ESTAB      0      0      10.10.2.22:3000      10.10.2.254:32777
users: (("node",pid=679,fd=44))
ESTAB      0      0      127.0.0.1:59022      127.0.0.1:27017
users: (("node",pid=679,fd=18))
ESTAB      0      0      127.0.0.1:59032      127.0.0.1:27017
users: (("node",pid=679,fd=23))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59464
users: (("mongod",pid=13568,fd=156))
ESTAB      0      0      127.0.0.1:59462      127.0.0.1:27017
users: (("node",pid=679,fd=46))
ESTAB      0      0      127.0.0.1:59070      127.0.0.1:27017
users: (("mongod",pid=13568,fd=112))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59032
users: (("mongod",pid=13568,fd=81))
ESTAB      0      0      127.0.0.1:27017      127.0.0.1:59048
users: (("mongod",pid=13568,fd=97))
root@rocket-chat-server: /etc# kill 1925
root@rocket-chat-server: /etc#
```

Рис. 2.38: Закрытие сессии с нарушителем

Все инциденты закрыты (рис. 2.39):

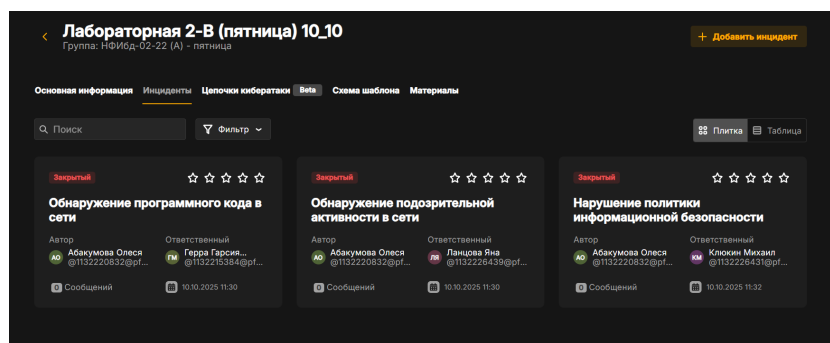


Рис. 2.39: Закрываются инциденты

Все уязвимости и последствия устранены (рис. 2.40):

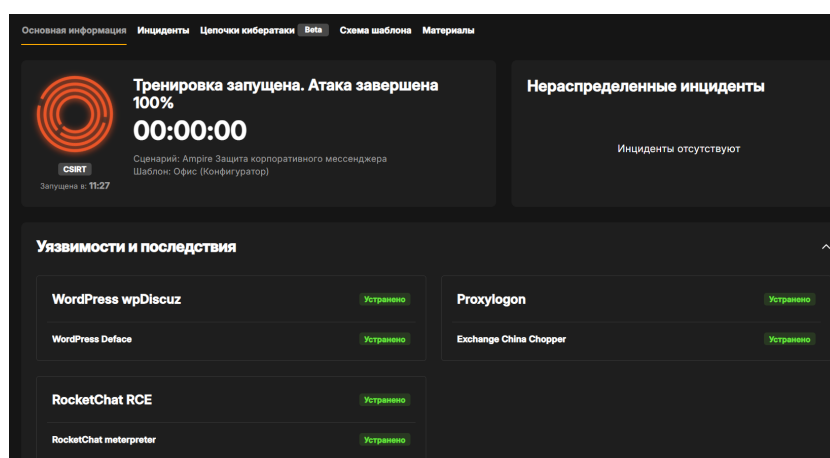


Рис. 2.40: Закрываются инциденты

3 Выводы

Мы устранили уязвимости и последствия после атаки злоумышленника на сайт Компании с целью получения доступа к внутренним ресурсам.